

Question:

to analyze a complete login workflow using Burp Suite.

1. Open Burp Suite and start intercepting traffic.
2. Visit a website that you own, a training lab, or a practice application.
3. Capture the following requests:
 - Home Page Request
 - Login Page Request
 - Login Submission Request
 - Logout Request
4. For each request identify:
 - Request Method
 - URL
 - Parameters
 - Headers
 - Cookies
 - Response Code
5. Send all captured requests to Repeater.
6. Analyze:
 - What changes after login?
 - Which cookie is responsible for maintaining the session?
 - Which parameters are sent to the server?
 - What information does the response contain?
7. Create a flow diagram showing:
Browser → Request → Server → Response → Login Success
8. Document your findings with screenshots.

Submission:

Prepare a PDF containing:

- Screenshots of all requests
- Screenshots of responses
- Session cookie details
- Login flow explanation
- Flow diagram

Aim

To analyze a complete login workflow using Burp Suite by intercepting HTTP requests and responses, identifying session cookies, and understanding the authentication process.

Introduction

Burp Suite is a web application security testing tool used for intercepting, analyzing, and modifying HTTP/HTTPS traffic between a browser and a web server. It helps security professionals and students understand how web applications communicate and manage user authentication.

In this experiment, Burp Suite Community Edition was used to capture and analyze the login workflow of a practice web application provided by PortSwigger Web Security Academy.

Tools Used

- Burp Suite Community Edition
- Mozilla Firefox Browser
- PortSwigger Web Security Academy Lab

Website Used

PortSwigger Web Security Academy Practice Lab

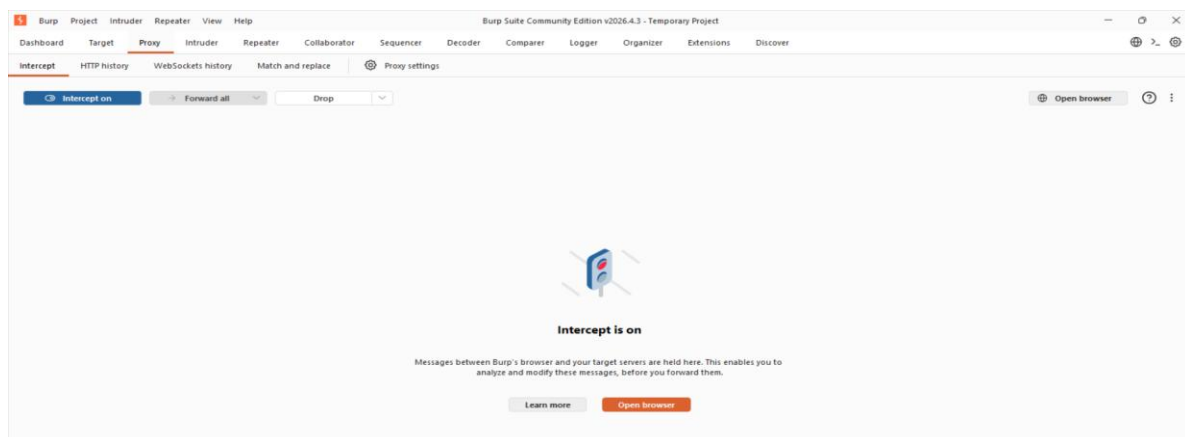
Procedure

Step 1: Starting Burp Suite

Burp Suite Community Edition was launched and the proxy intercept option was enabled from: Proxy → Intercept

Intercept was turned ON to capture browser requests.

Screenshot:



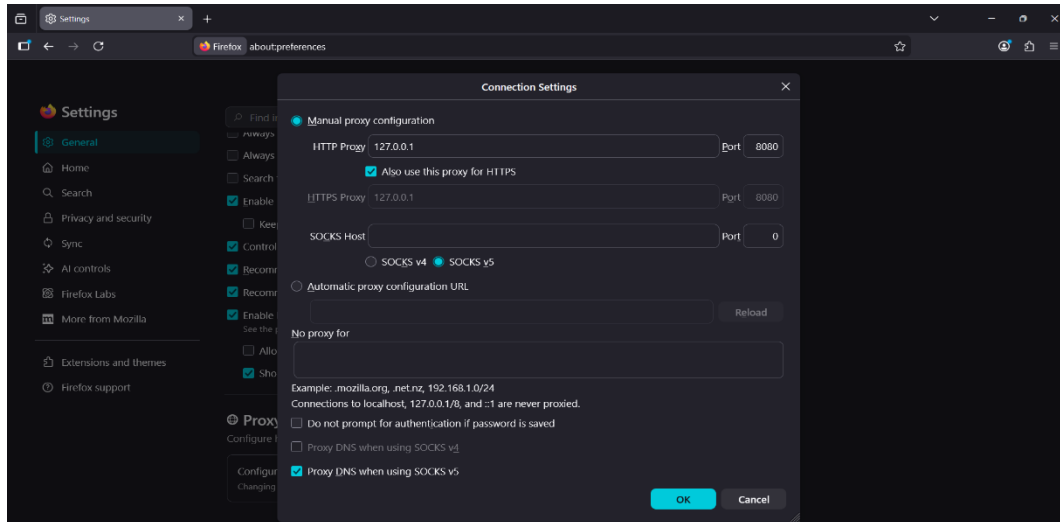
Step 2: Configuring Browser Proxy

Mozilla Firefox was configured to use Burp Suite proxy settings:

IP Address: 127.0.0.1

Port: 8080

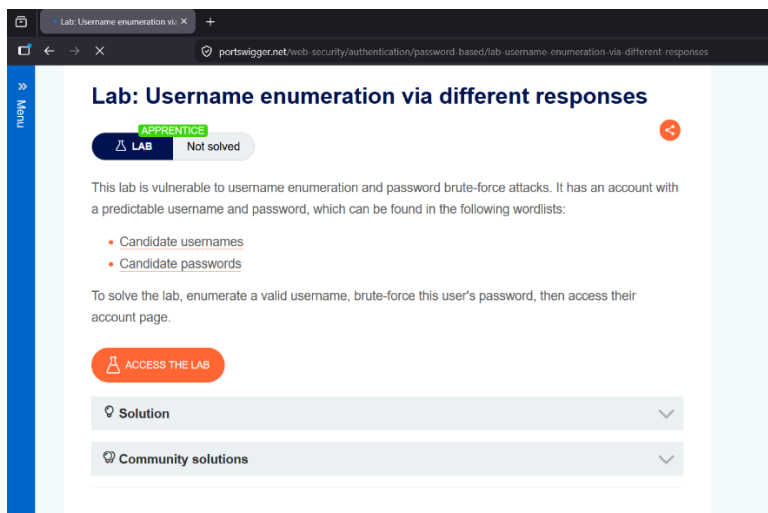
Screenshot:

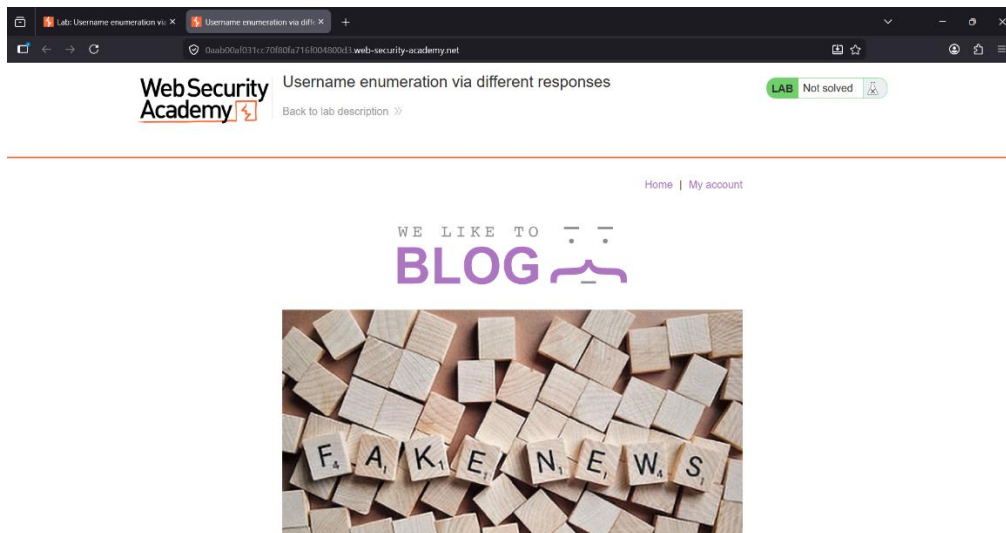


Step 3: Opening the PortSwigger Lab

- Opened the PortSwigger Web Security Academy website.
- Navigated to Authentication Labs.
- Selected a practice lab.
- Clicked:
Access the Lab
- The practice website opened in the browser.

Screenshot:





Step 4: Capturing Home Page Request

The practice lab homepage was opened in Firefox. Burp Suite intercepted the HTTP request successfully.

Home Page Request: GET / HTTP/2

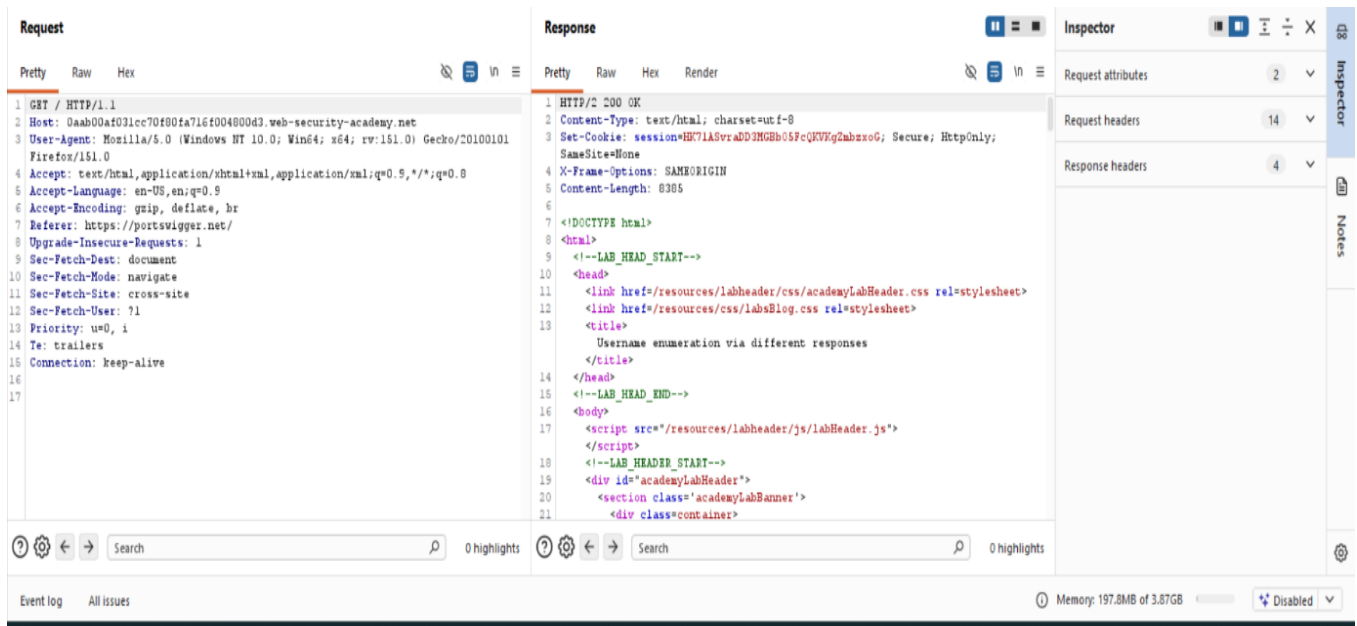
Observations

Parameter	Value
Method	GET
Response Code	200
Purpose	Requesting homepage

Screenshot:

The screenshot displays the Burp Suite interface with the following details:

- Request Tab:** Shows an intercepted GET request to `https://0aab00af031ec70f00fa716f004000d41.web-security-academy.net` with status 200.
- Response Tab:** Shows the corresponding 200 OK response from `142.250.70.66`. The response headers include `Content-Type: text/html`, `Set-Cookie: session=HKT7IASvraADJINGBb05FcQVYgZabxroG; Secure; HttpOnly; SameSite=None`, and `X-Frame-Options: SAMEORIGIN`.
- Inspector:** Displays the HTML body of the response, which includes the lab title and a 'LAB Not solved' status.



Step 5: Capturing Login Page Request

The “My Account” option was clicked to open the login page.

Login Page Request: POST /login HTTP/2

Observations

Parameter **Value**

Method POST

Response Code 200

Purpose Opening login form

The following credentials were entered in the login form:

Username: wiener

Password: peter

After clicking the login button, Burp Suite intercepted the login submission request.

Captured Login Request

POST /login HTTP/2

Host: 0aab00af031cc70f80fa716f004800d3.web-security-academy.net

Cookie: session=HK71ASvraDD3MGBbO5FcQKVKgZmbzxoG

Content-Type: application/x-www-form-urlencoded

username=wiener&password=peter

Burp Suite Community Edition v2023.4.3 - Temporary Project

Burp Suite

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Discover

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

Pro version only

Filter on

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response
227	https://www.gstatic.com	GET	/youtube/img/lotte/subscribe_act...			200	4320	JSON	json			✓	194.232.70.327	12:53:36 9 L...	8080	43	
227	https://mozilla-ottp.fastly.c...	POST	/			200	765					✓	199.232.105.91	12:53:36 9 L...	8080	307	
228	https://0aab00af031c70f80f...	GET	/login			200	3287	HTML		Username enumeration...		✓	79.125.84.16	12:53:36 9 L...	8080	179	
228	https://incoming.telemetry.m...	POST	/submit/firefox-desktop/newtab/1/...			200	622	text				✓	34.120.208.123	12:53:41 9 L...	8080	316	
231	https://0aab00af031c70f80f...	GET	/academyLabHeader			101	147					✓	79.125.84.16	12:53:41 9 L...	8080	204	
231	https://googleads.g.doublecl...	GET	/pagead/id			200	849	JSON				✓	142.250.146.154	12:53:54 9 L...	8080	86	
231	https://googleads.g.doublecl...	GET	/pagead/id			200	849	JSON				✓	142.250.146.154	12:53:54 9 L...	8080	83	
234	https://0aab00af031c70f80f...	POST	/login			200	3352	HTML		Username enumeration...		✓	34.246.129.62	12:55:57 9 L...	8080	202	

Request

Raw

Hex

1 POST /login HTTP/1.2

2 Host: 0aab00af031c70f80f716f004800d3.web-security-academy.net

3 Cookie: session=H71A5vraAD03NGb05FCQVQZg2abxsoG

4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0) Gecko/20100101 Firefox/151.0

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

6 Accept-Language: en-US,en;q=0.9

7 Accept-Encoding: gzip, deflate, br

8 Content-Type: application/x-www-form-urlencoded

9 Content-Length: 30

10 Referer: https://0aab00af031c70f80f716f004800d3.web-security-academy.net/

11 https://0aab00af031c70f80f716f004800d3.web-security-academy.net/login

12 Origin-Insecure-Requests: 1

13 Sec-Fetch-Dest: document

14 Sec-Fetch-Mode: navigate

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-User: ?1

17 Priority: u=0, i

18 Te: trailers

19

20 username=winner&password=ptex

Response

Raw

Hex

Render

1 HTTP/2 200 OK

2 Content-Type: text/html; charset=utf-8

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 3244

5

6 <!DOCTYPE html>

7 <html>

8 <!-- LAB HEAD START-->

9 <head>

10 <link href="/resources/labheader/css/academyLabHeader.css rel=stylesheet">

11 <link href="/resources/css/labs.css rel=stylesheet">

12 <title>

13 Username enumeration via different responses

14 <body>

15 <!-- LAB HEAD END-->

16 <script src="/resources/labheader/js/labHeader.js">

17 </script>

18 <!-- LAB HEADERS START-->

19 <div id="academyLabBanner">

20 <div class="container">

21 <div class="logo">

22 <div class="title">CONTAINER</div>

23 </div>

Inspector

Request headers

20

Name

Value

scheme

https

method

POST

path

/login

authority

0aab00af031c70f80f...

cookie

session=H71A5vraAD03NGb05FCQVQZg2abxsoG

user-agent

Mozilla/5.0 (Windows...)

accept

text/html,application/...

accept-language

en-US,en;q=0.9

accept-encoding

gzip, deflate, br

content-type

application/x-www-f...

content-length

30

origin

https://0aab00af031c...

referrer

https://0aab00af031c...

upgrade-insecure-re...

1

sec-fetch-dest

document

sec-fetch-mode

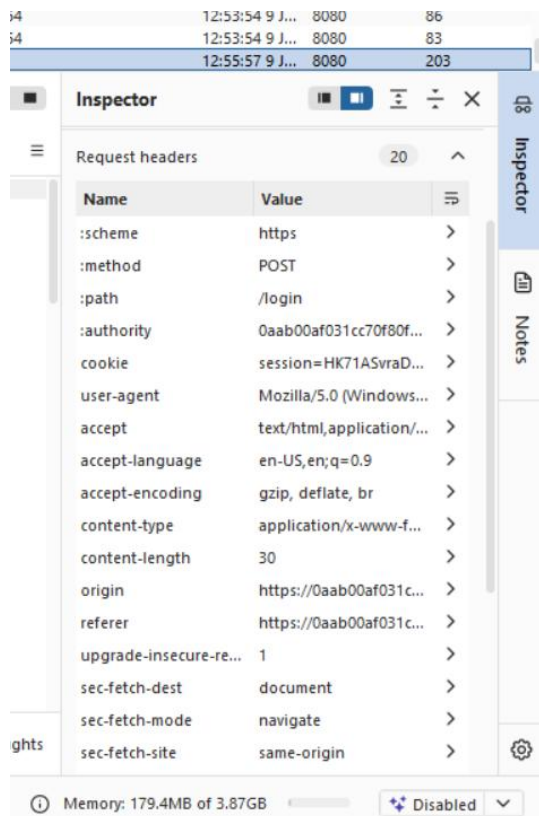
navigate

sec-fetch-site

same-origin

Request body parameters			2	>
Name	Value	It		
username	wiener			>
password	peter			>

Name	Value	
Method	POST	>
Path	/login	>



Analysis of Login Submission Request

Request Method

POST:-POST method was used to securely transmit credentials to the server.

URL:- /login

This endpoint handled user authentication.

Parameters Sent to Server

Parameter Description

username Username entered by user

password Password entered by user

Parameters identified:

- username=wiener
- password=peter

Important Headers

Header	Purpose
Host	Identifies target server
Cookie	Maintains session
Content-Type	Specifies form data format
Referer	Indicates previous webpage
User-Agent	Browser information

Screenshot:

The screenshot shows a web browser's developer tools interface, specifically the 'Request' tab. The top status bar indicates a POST request to `https://0aab00af031cc70f80fa716f004800d3.web-security-academy.net/login` with a status of 200. The 'Request' tab is active, showing the raw HTTP request details. The request is a POST to `/login` using HTTP/2. The headers include `Host`, `Cookie`, `User-Agent`, `Accept`, `Accept-Language`, `Accept-Encoding`, `Content-Type`, `Content-Length`, `Origin`, `Referer`, `Upgrade-Insecure-Requests`, `Sec-Fetch-Dest`, `Sec-Fetch-Mode`, `Sec-Fetch-Site`, `Sec-Fetch-User`, `Priority`, and `Te`. The body of the request is `username=wiener&password=peter`. The interface includes tabs for 'Pretty', 'Raw', and 'Hex', and a search bar at the bottom.

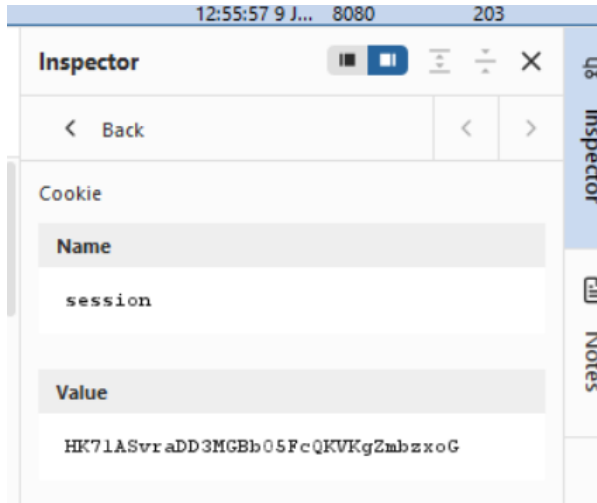
```
1 POST /login HTTP/2
2 Host: 0aab00af031cc70f80fa716f004800d3.web-security-academy.net
3 Cookie: session=HK71ASvraDD3HGBb05FcQKVKgZabzxoG
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0) Gecko/20100101 Firefox/151.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 30
10 Origin: https://0aab00af031cc70f80fa716f004800d3.web-security-academy.net
11 Referer: https://0aab00af031cc70f80fa716f004800d3.web-security-academy.net/login
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 username=wiener&password=peter
```

Session Cookie Identified

session=HK71ASvraDD3MGBbO5FcQKVKgZmbzxoG

This session cookie maintained communication between browser and server.

Screenshot:



Step 6: Login Response Analysis

After forwarding the login request, the server generated a response.

Captured Response

HTTP/2 200 OK

Content-Type: text/html

Response Analysis

Parameter	Observation
Response Code	200 OK
Response Type	HTML
Authentication Result	Login Failed
Session Cookie	Present

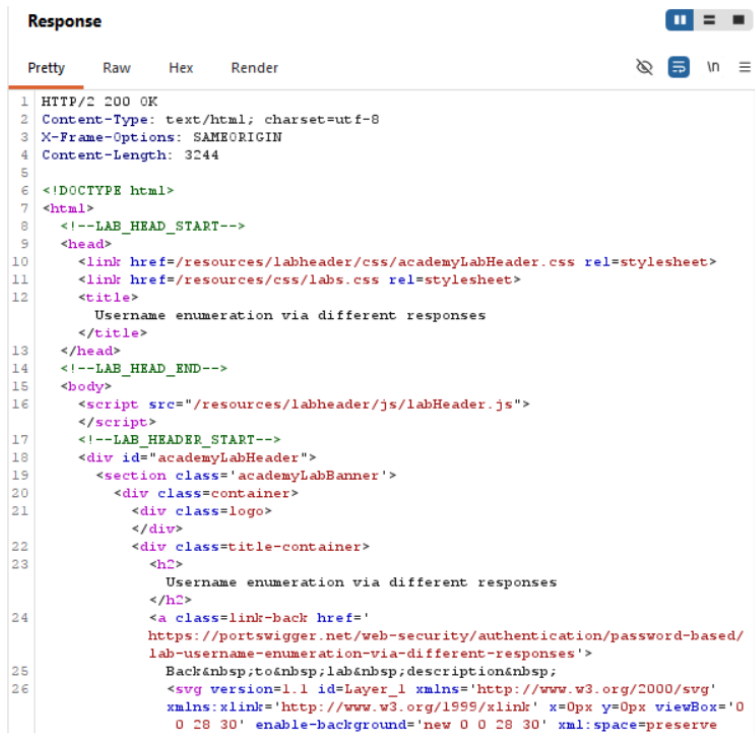
Response Body Observation

The response contained an authentication failure message:

Invalid username or password

This indicated that the server validated user credentials before granting access.

Screenshot:



```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3244
5
6 <!DOCTYPE html>
7 <html>
8   <!--LAB_HEAD_START-->
9   <head>
10     <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11     <link href=/resources/css/labs.css rel=stylesheet>
12     <title>
13       Username enumeration via different responses
14     </title>
15   </head>
16   <!--LAB_HEAD_END-->
17   <body>
18     <script src=/resources/labheader/js/labHeader.js>
19     </script>
20     <!--LAB_HEADER_START-->
21     <div id="academyLabHeader">
22       <section class='academyLabBanner'>
23         <div class=container>
24           <div class=logo>
25           </div>
26           <div class=title-container>
27             <h2>
28               Username enumeration via different responses
29             </h2>
30             <a class=link-back href='
31               https://portswigger.net/web-security/authentication/password-based/
32               lab-username-enumeration-via-different-responses'>
33               Back&nbsp;to&nbsp;lab&nbsp;description&nbsp;
34             <svg version=1.1 id=Layer_1 xmlns='http://www.w3.org/2000/svg'
35               xmlns:xlink='http://www.w3.org/1999/xlink' x=0px y=0px viewBox='0
36               0 28 30' enable-background='new 0 0 28 30' xml:space=preserve
```

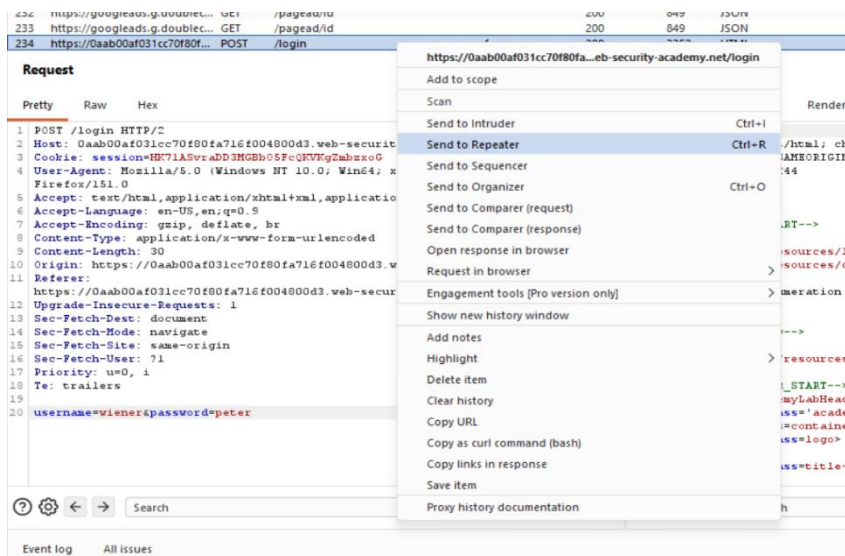
Step 7: Sending Request to Repeater

The captured login request was analyzed further using Burp Repeater.

Procedure

- Right-clicked login request
- Selected:
Send to Repeater
- Opened Repeater tab
- Modified request parameters
- Sent modified requests to server

Screenshot:



Repeater Analysis

Different usernames and passwords were tested.

Example:

- username=admin
- password=peter

Observations

- Different credentials generated different responses.
- Response lengths changed.
- Authentication behavior changed based on parameters.
- Session cookie remained active.

Screenshot:

Request

Pretty Raw Hex

```
1 POST /login HTTP/2
2 Host: 0ae3007903c738658178434300510031.web-security-academy.net
3 Cookie: session=58UoIia6HLfIFs3duLZKwfwWUPkEUVCL
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0) Gecko/20100101 Firefox/151.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 29
10 Origin: https://0ae3007903c738658178434300510031.web-security-academy.net
11 Referer: https://0ae3007903c738658178434300510031.web-security-academy.net/login
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 username=admin&password=peter
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 3244
5
6 <!DOCTYPE html>
7 <html>
8   <!--LAB_HEAD_START-->
9   <head>
10     <link href=/resources/labheader/css/academyLabHeader.css rel=
11       stylesheet>
12     <link href=/resources/css/labs.css rel=stylesheet>
13     <title>
14       Username enumeration via different responses
15     </title>
16   </head>
17   <!--LAB_HEAD_END-->
18   <body>
19     <script src=/resources/labheader/js/labHeader.js>
20     </script>
21     <!--LAB_HEADER_START-->
22     <div id="academyLabHeader">
23       <section class='academyLabBanner'>
24         <div class=container>
25           <div class=logo>
26           </div>
27           <div class=title-container>
28             <h2>
29               Username enumeration via different responses
30             </h2>
31             <a class=link-back href='
32               https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-di
33               fferent-responses'>
```

0 highlights

Inspector

Request attributes

2

^

Protocol

HTTP/1

HTTP/2

Name	Value	
Method	POST	>
Path	/login	>

Request query parameters

0

^

Request body parameters

2

^

Name	Value	
username	admin	>
password	peter	>

Inspector

< Back

<

>

Cookie

Name

session

Value

58UoIia6HLfIFs3duLZKwfwWUPr:EUVCL

Decoded from:

URL encoding

+

58UoIia6HLfIFs3duLZKwfwWUPr:EUVCL

Cancel

Apply changes

Inspector

Name

Value

:scheme

https

>

:method

POST

>

:path

/login

>

:authority

0ae3007903c7386581...

>

cookie

session=58Uolia6HLfl...

>

user-agent

Mozilla/5.0 (Windows...

>

accept

text/html,application/...

>

accept-language

en-US,en;q=0.9

>

accept-encoding

gzip, deflate, br

>

content-type

application/x-www-f...

>

content-length

29

>

origin

https://0ae3007903c7...

>

referrer

https://0ae3007903c7...

>

upgrade-insecure-re...

1

>

sec-fetch-dest

document

>

sec-fetch-mode

navigate

>

sec-fetch-site

same-origin

>

sec-fetch-user

?1

>

priority

u=0, i

>

te

trailers

>

Response headers

3

^

Name	Value	
Content-Type	text/html; charset=ut...	>
X-Frame-Options	SAMEORIGIN	>
Content-Length	3244	>

Settings

Step 8: Logout Request Analysis

After login workflow analysis, logout functionality was analyzed. The logout button on the application was clicked, and Burp Suite intercepted the request.

Screenshot:

The screenshot displays the Burp Suite interface with a captured HTTP request and response for a logout operation. The 'Request' tab is active, showing the raw HTTP data. The request is a GET request to `/a2/logout?client_id=F1PVGMoisq...` with a status code of 200. The 'Response' tab is also visible, showing the raw HTTP data for the response. The response is a 302 Found status, indicating a redirect to `https://portswigger.net/`. The 'Inspector' panel on the right shows the request attributes, including the method (GET), path (`/a2/logout`), and request cookies (e.g., `Sessionid=CTDIBMeIQv4Vps...`).

Captured Logout Request

GET /logout HTTP/2

Host: 0aab00af031cc70f80fa716f004800d3.web-security-academy.net

Cookie: session=HK71ASvraDD3MGBbO5FcQKVKGzmbzxoG

Screenshot:

The screenshot displays the Burp Suite interface with a captured HTTP request. The 'Request' tab is active, showing the raw HTTP data. The request is a GET request to `/logout` with a status code of 200. The 'Inspector' panel on the right shows the request attributes, including the method (GET), path (`/logout`), and request cookies (e.g., `session=HK71ASvraDD3MGBbO5FcQKVKGzmbzxoG`).

Logout Response

HTTP/2 302 Found

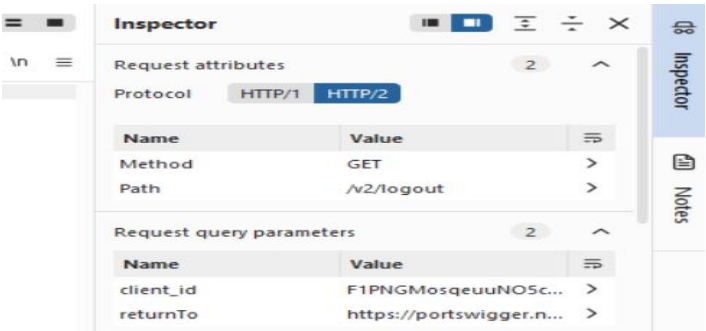
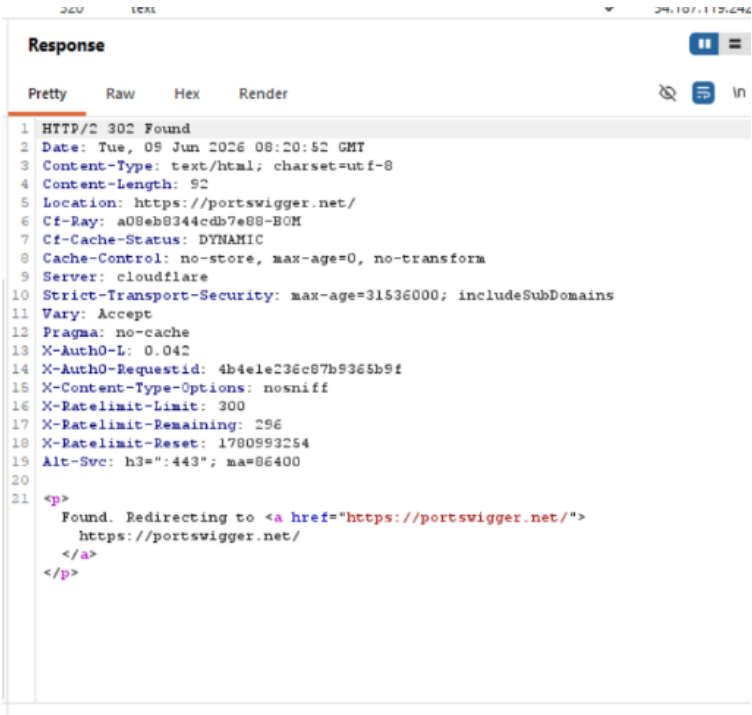
Location: /

Set-Cookie: session=; expires=Thu, 01 Jan 1970 00:00:00 GMT

Logout Response Analysis

Parameter	Observation
Response Code	302 Found
Redirect Location	Homepage
Session Status	Expired
Authentication Status	Logged Out

Screenshot:



Session Management Analysis

The application used session cookies to maintain authentication state between browser and server.

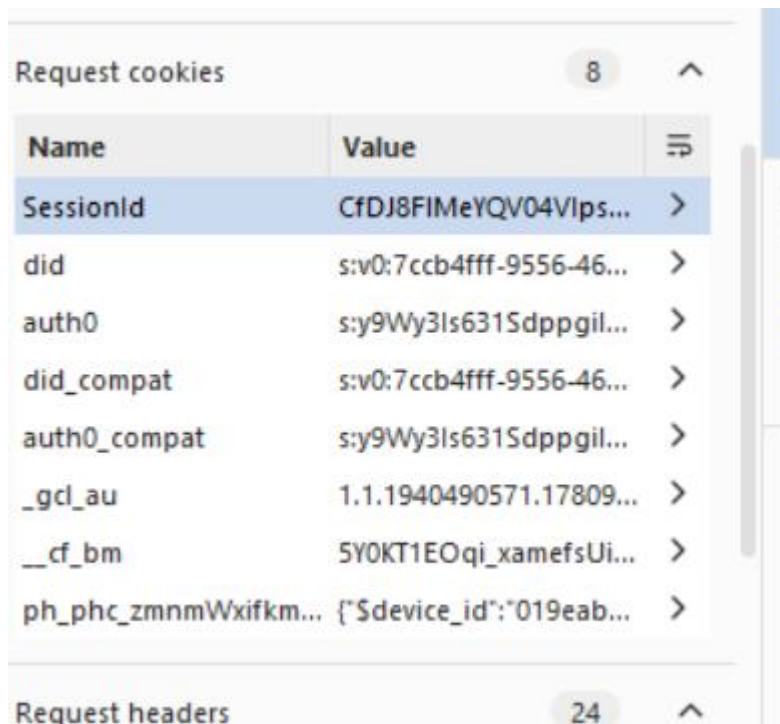
Session Cookie

session=HK71ASvraDD3MGBbO5FcQKVKgZmbzxoG

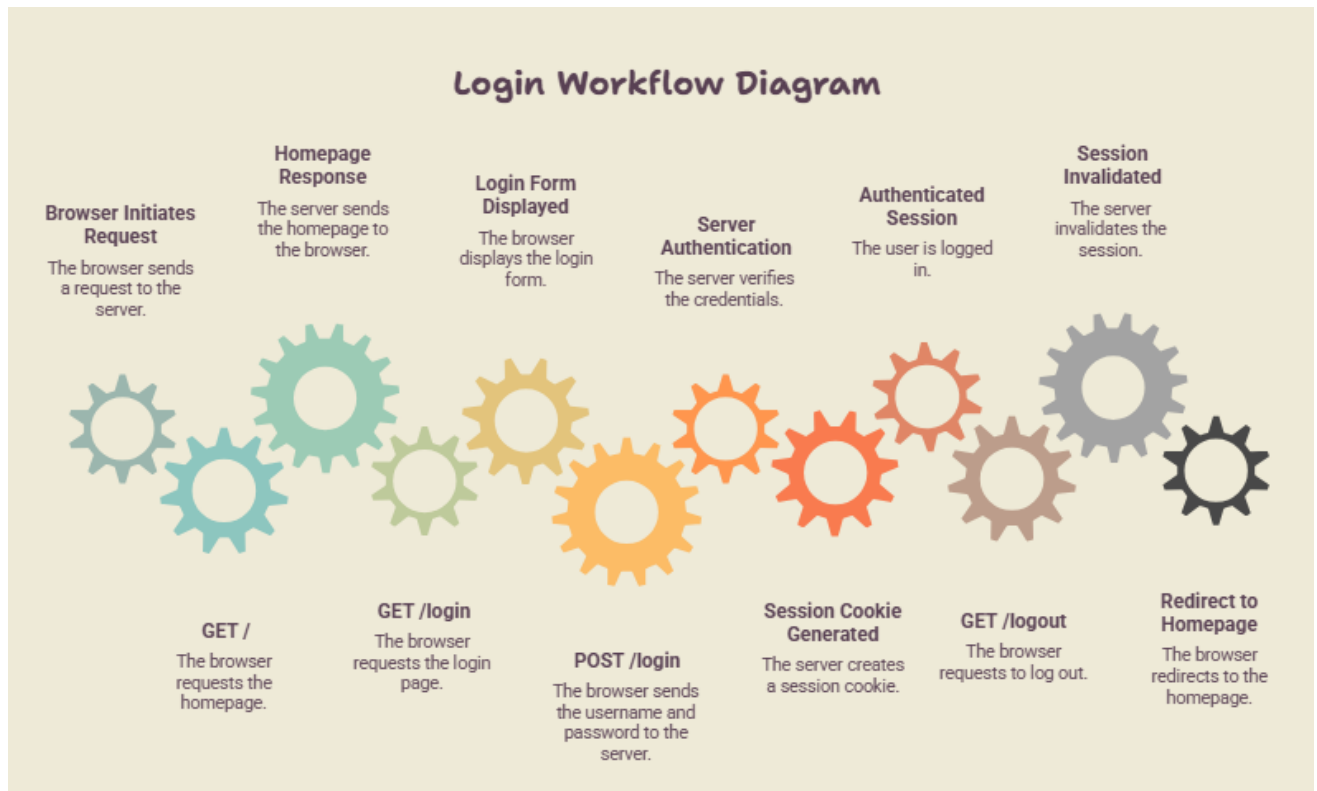
Purpose of Session Cookie

- Maintains user session
- Tracks authentication state
- Identifies client requests
- Enables persistent communication

Screenshot:



Login Workflow Diagram



Findings

- Burp Suite successfully intercepted HTTP requests and responses.
- GET and POST methods were analyzed.
- Login credentials were transmitted using POST requests.
- Session cookies maintained user sessions.
- Repeater allowed modification and testing of requests.
- Logout functionality properly invalidated session cookies.

Conclusion

This experiment successfully demonstrated how Burp Suite can be used to analyze complete login workflows in web applications. Different HTTP requests, responses, headers, parameters, cookies, and session management techniques were analyzed using the PortSwigger practice lab. The experiment provided practical understanding of authentication workflows and web application communication mechanisms.